



Zero Trust Architecture Product Capabilities

VMware Cloud Foundation 9.1
VMware vDefend 9.1

June 2026

Table of Contents

Disclaimer.....3

Third Party Identifiers & Mappings3

Executive Summary.....4

Introduction4

Product Definitions5

Secure Controls Framework.....5

Never Trust, Always Verify: Identity and Access 6

Verify Every Device: Endpoint Posture and Trust7

Segment Everything: Network and Environment Isolation..... 8

Isolate Workloads: Application and Workload Protection 9

Protect Data Throughout Its Lifecycle..... 10

See Everything: Visibility and Analytics..... 11

Automate the Response: Orchestration and Enforcement.....12

Mapping to the NIST SP 800-207 Tenets..... 13

Mapping to the NIST SP 800-207 Deployment Approaches..... 13

Mapping to the CISA Zero Trust Maturity Model 14

Mitigating ZTA Threats from SP 800-207..... 15

Capability Coverage Matrices..... 16

 VMware Cloud Foundation 16

 VMware vDefend 18

 VCF Advanced Cyber Compliance 19

Conclusion..... 19

Resources..... 20

Disclaimer

This document is intended to provide general guidance for organizations that are considering Broadcom solutions. The information contained in this document is for educational and informational purposes only. This document is not intended to provide advice and is provided “AS IS.” Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of requirements and effectiveness of implementations.

Third Party Identifiers & Mappings

This document includes regulatory compliance and security control identifiers from external sources as a convenience to end users. This does not constitute endorsement, in either direction.

There is not a one-to-one mapping of product capabilities to third-party controls. A product capability, or set of capabilities, may be applicable to multiple controls. Conversely, a control may be satisfied with the use of multiple capabilities.

Control identifier numbers have been included from the [Secure Controls Framework](#), version 2026.1, under the terms of the [Creative Commons Attribution-NoDerivatives 4.0 International Public License](#). No modifications have been made to the control identifier numbers under the terms of the license.

Executive Summary

VMware Cloud Foundation (VCF), with the VMware vDefend and VCF Advanced Cyber Compliance advanced services, provides the infrastructure-layer capabilities organizations need to build a Zero Trust architecture aligned with NIST Special Publication 800-207, the U.S. Department of Defense (DoD) Zero Trust Reference Architecture and Capability Execution Roadmap, and the CISA Zero Trust Maturity Model.

Across the seven NIST 800-207 tenets and the seven DoD Zero Trust pillars, the combined stack contributes to every area an infrastructure platform can reach. Coverage is strongest in Network and Environment, where vDefend's distributed firewall delivers identity- and application-context-aware micro-segmentation enforced inside the hypervisor; in User, where VCF SSO federation and platform-wide role-based access control enforce least privilege; in Device, where Secure Boot, TPM attestation, and continuous compliance establish host trust; and in Data, where storage and virtual machine encryption, customer-controlled keys, and the replication and recovery capabilities of VCF Protection and Recovery protect data and preserve its availability.

The boundaries are equally clear. VCF is the platform on which a Zero Trust architecture is built, not the whole architecture. It depends on the enterprise identity provider for multifactor and continuous authentication, and it does not provide SIEM, user and entity behavior analytics, data loss prevention, or Zero Trust Network Access as products in their own right. It produces the telemetry, enforcement, and recovery that those systems and processes build on. The capability claims in this paper are drawn from a control-by-control assessment of VCF 9.1, vDefend, and VCF Protection and Recovery against the Secure Controls Framework (SCF); the crosswalk used in this paper maps those SCF controls to the NIST 800-207 tenets and the DoD Zero Trust capabilities. These mappings describe product capability, not a compliance certification.

Introduction

Zero Trust is a security model built on the principle that no actor, system, or network segment should be automatically trusted, regardless of its location. Every access request is verified, every session is authorized independently, and communication channels are protected according to risk and policy, whether they originate inside or outside the network perimeter.

Several frameworks define the current state of Zero Trust architecture. NIST Special Publication 800-207, published in August 2020, establishes the foundational principles through seven tenets, a logical component model (Policy Engine, Policy Administrator, Policy Enforcement Point), and three deployment approaches: enhanced identity governance, micro-segmentation, and network infrastructure and software-defined perimeters. Executive Order 14028, *Improving the Nation's Cybersecurity* (May 2021), directed federal agencies to adopt Zero Trust architectures. OMB Memorandum M-22-09 (January 2022) translated that direction into specific requirements organized around five pillars: identity, devices, networks, applications and workloads, and data. The U.S. Department of Defense Zero Trust Reference Architecture (version 2.0) and the DoD Zero Trust Strategy, published in 2022, build on the NIST foundation and organize Zero Trust into seven operational pillars: User, Device, Network and Environment, Application and Workload, Data, Visibility and Analytics, and Automation and Orchestration. The companion DoD Zero Trust Capability Execution Roadmap decomposes those pillars into 45 capabilities and 152 activities (91 target, 61 advanced) that constitute a measurable implementation. The CISA Zero Trust Maturity Model (version 2.0, April 2023) provides a progression path with four maturity levels (Traditional, Initial, Advanced, and Optimal) across these pillars.

Product Definitions

This paper covers VMware Cloud Foundation and two separately licensed advanced services, kept distinct because each is licensed and deployed independently and contributes differently.

- **VMware Cloud Foundation (core)** is the full-stack platform spanning compute, storage, networking, and management. It provides the identity, host trust, workload isolation, encryption, software-defined networking, logging, and lifecycle foundation on which the rest is built.
- **VMware vDefend** is a separately licensed advanced service that builds on NSX, VCF's networking layer, to add network security enforcement and threat detection. Its management plane is the Security Services Platform (SSP).
- **VCF Advanced Cyber Compliance (ACC)** is a separately licensed advanced service. Depending on version, deployment model, and entitlement, ACC provides entitlement to, or enables, capabilities such as compliance enforcement, cyber and disaster recovery (VCF Protection and Recovery), policy-based VPC connectivity, and confidential computing. These capabilities have distinct deployment models, logging behavior, and role models rather than a single uniform control surface.

The table below lists the key components of each offering and where it contributes to the Zero Trust pillars.

Offering	Licensing	Key components	Primary Zero Trust contribution
VMware Cloud Foundation	Base platform	VMware Certificate Authority (VMCA), VCF SSO and role-based access control, ESX with Secure Boot and TPM attestation, vSAN and VM encryption, NSX software-defined networking, VCF Operations, VCF Log Management, vSphere Lifecycle Manager	User identity and least privilege, Device host trust, the Network foundation, Data encryption, Visibility, and configuration and patch Automation
VMware vDefend	Separately licensed Advanced Service	Distributed Firewall, Gateway Firewall, Identity Firewall, Application ID, Distributed IDS/IPS, Network Detection and Response, Advanced Threat Prevention, Security Intelligence (managed through the Security Services Platform)	Network and Environment enforcement through micro-segmentation, network Resource Authorization, and the network layers of Visibility and Analytics
VCF Advanced Cyber Compliance	Separately licensed Advanced Service	VCF Protection and Recovery, Confidential Computing (Intel TDX and AMD SEV-SNP), SaltStack-based compliance automation, VCF Operations Security Posture Management, Continuous Compliance Enablement	Application and Workload memory isolation, Device and Automation continuous compliance, and Data resilience through replication, disaster-recovery orchestration, and ransomware recovery

Where this paper discusses routing and connectivity it refers to NSX; where it discusses firewalling, segmentation enforcement, and threat detection it refers to vDefend. Capabilities delivered through an Advanced Service are labeled as such at first mention, and the coverage matrices present each offering separately so that readers can see which capability sits in which offering.

Secure Controls Framework

The capability claims in this paper are grounded in a control-by-control assessment of VCF, vDefend, and the VCF Advanced Cyber Compliance against the Secure Controls Framework (SCF), version 2026.1.1. The SCF is an open catalog of cybersecurity and data protection controls that maps to a broad range of regulations, standards, and frameworks. The crosswalk used in this paper maps SCF controls to the NIST SP 800-207 tenets and the DoD Zero Trust capabilities; the CISA Zero Trust Maturity Model is mapped by pillar correspondence to that same evidence. Coverage is reported at the infrastructure layer, as described in the note preceding the coverage tables. All described and mapped product capabilities can be found in the respective product documentation.

Never Trust, Always Verify: Identity and Access

NIST Tenets 3 and 6. DoD User pillar.

The core of Zero Trust is the shift from network-location-based trust to identity-based trust. Both NIST SP 800-207 and the DoD Zero Trust Strategy require that every access request be authenticated and authorized independently, that access be scoped to the minimum privileges needed, and that multifactor authentication be enforced. In the DoD capability model, this pillar covers User Inventory, Conditional User Access, Multi-Factor Authentication, Privileged Access Management, Identity Federation and Credentialing, Least Privileged Access, Continuous Authentication, and an Integrated ICAM Platform.

VCF addresses identity federation directly. VCF SSO is the centralized authentication service, issuing security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and VCF Automation. vCenter and other components can federate with an external enterprise identity provider through supported SAML, OpenID Connect (OIDC), or directory-based integrations. Because authentication is delegated to the enterprise identity provider in a federated model, organizations can enforce their own multifactor authentication, conditional access rules, device posture checks, and geographic restrictions before a session token ever reaches VCF. VCF does not issue multifactor credentials itself; it consumes the assurance established by the identity provider, which is the architecturally correct division of responsibility for an infrastructure platform.

Role-based access control spans the entire platform and is the basis for least-privileged access. Permissions are scoped both by function and by inventory location, so a user can perform only the activities specified by the role assigned to them, on the specific object to which that role is assigned. VCF-level roles allow centralized assignment of privilege bundles across vCenter, NSX, VCF Operations, and VCF Automation from a single management interface, and custom roles can combine component-level permissions. Role assignments can be scoped to the entire SSO federation or to individual VCF instances. Individual components retain their own authorization models and supported integration paths, so organizations should validate role mapping and federation behavior per component. VCF can participate in just-in-time or time-limited access workflows when integrated with enterprise identity and privileged access management tooling; a full privileged access management program depends on that external tooling and the supporting organizational process.

For supported automation workflows and APIs, VCF SSO provides OAuth 2.0 and API-token authentication with scoped, revocable tokens, reducing the need for embedded credentials in scripts. A service account's actions are constrained by its narrowly scoped role-based permissions, so a compromised token is limited to the operations its permissions allow.

At the credential and key layer, VCF includes the VMware Certificate Authority (VMCA), an internal certificate authority that ships with every vSphere deployment and provides the chain of trust for components across the stack. This internal public key infrastructure, together with federation through standard protocols, supports integration with an enterprise Integrated ICAM Platform. VCF supplies the infrastructure-tier certificate authority and federation rather than enterprise identity governance, credential issuance for users, or access recertification, which remain functions of the enterprise ICAM system. VCF supports centralized identity configuration and password-policy controls where local or directory-backed authentication is used; in federated deployments, password policy, multifactor authentication, conditional access, and session-risk decisions are enforced by the external identity provider.

vDefend contributes to this pillar at the network layer. The Identity Firewall ties firewall rules to Active Directory user and group membership, so network access decisions follow organizational role rather than IP address, including for Virtual Desktop Infrastructure sessions. vDefend's own management plane, the Security Services Platform (SSP), enforces role-based access control through built-in roles with differentiated permissions, giving its administration the same least-privilege treatment as the platform it protects.

Verify Every Device: Endpoint Posture and Trust

NIST Tenet 5. DoD Device pillar.

The DoD Zero Trust model requires that every device demonstrate its security posture before being granted access. The capability set here spans Device Inventory, Device Detection and Compliance, Device Authorization with Real-Time Inspection, automated Asset, Vulnerability and Patch Management, and Endpoint and Extended Detection and Response. In a VCF environment, the ESX hypervisor host is the foundational device, and VCF establishes and continuously verifies host trustworthiness.

Secure Boot validates the ESX boot chain through firmware-level signature verification. TPM 2.0 integration enables Measured Boot, which attests the boot process. Together they establish a hardware root of trust: the host can demonstrate that it booted the software it was supposed to boot and that the software has not been modified. VCF Operations can alert on attestation failures, and the VCF Security Baseline provides hardening guidance for TPM configuration. This is the mechanism the DoD Device pillar calls for when it requires a hardware root of trust as the basis for device authorization.

Device and asset inventory is maintained continuously. vCenter holds the authoritative inventory of all managed objects, organized hierarchically from the root folder through datacenters, clusters, and hosts. VCF Operations maintains a configuration-item inventory that functions as a CMDB-like record for the virtual infrastructure, with integration points for external CMDB platforms such as ServiceNow. Infrastructure components, services, and hosts authenticate to one another using cryptographically based, bidirectional authentication anchored in VMCA-issued certificates, so device identity is verified before connections are established.

Posture assessment and continuous compliance, delivered through VCF Operations Security Posture Management and Continuous Compliance Enablement (part of the VCF Advanced Cyber Compliance), run checks against built-in benchmarks including the VCF Configuration and Hardening Guide, PCI DSS v4.0.1 for VCF, and VCF 9 General Controls. Assessment results flow to a centralized dashboard, and remediation can be applied selectively or at fleet scale. New benchmark content can be delivered outside the release cycle as cryptographically signed packages, so the compliance baseline can evolve without waiting for a platform upgrade. This addresses the DoD's continuous diagnostics and mitigation requirement at the infrastructure layer.

Automated patch and vulnerability management is delivered through VCF Operations and vSphere Lifecycle Manager, which together form a unified lifecycle management plane. VCF Operations coordinates patch releases that deliver time-sensitive security fixes, with pre-update health checks and compatibility verification. Configuration drift detection compares the running state of clusters against desired-state templates, with scheduled checks, downloadable reports, and alarm integration. Image integrity verification confirms, by SHA-256 checksum, that ESX images have not been modified, including when images move between vCenter instances, and the platform provides change-detection and integrity-monitoring capabilities on management appliances that contribute to a file integrity monitoring strategy. ESX also supports integration with third-party endpoint and antimalware security partners that observe host activity, providing endpoint visibility that complements the platform's native controls.

Endpoint and extended detection and response are areas where VCF supplies the supporting telemetry and host integrity controls rather than a full EDR product. VCF Log Management provides near-real-time log analysis, event correlation, and forwarding to external SIEM and EDR/XDR platforms through syslog integration on every major component. vDefend extends detection to the network layer: its Network Detection and Response (NDR) capability classifies suspicious traffic, associates detections with specific MITRE ATT&CK techniques and tactics, and correlates individual events into campaigns for triage. Unified endpoint management and mobile device management, which apply to user endpoints rather than data center infrastructure, are outside the scope of these products.

Segment Everything: Network and Environment Isolation

NIST Tenet 2. DoD Network and Environment pillar.

Both NIST SP 800-207 and the DoD Zero Trust model require that networks be segmented at the workload level, that traffic be encrypted, and that network access decisions be based on identity and policy rather than location. The DoD capability set here covers Data Flow Mapping, Software Defined Networking, Macro Segmentation, and Micro Segmentation. This is the strongest area of the combined story: across these four capabilities, the assessment found a direct contribution in every case.

NSX provides the software-defined networking foundation that decouples workload connectivity from the physical topology. The networking layer is abstracted from physical hardware and managed programmatically through NSX Manager and its API. Overlay networks create logical segments that span physical boundaries, and mutual TLS authentication is used between NSX infrastructure components so that even infrastructure-to-infrastructure communication is cryptographically verified. At the macro level, VCF uses VLANs and vSphere Distributed Switches to isolate traffic by function, keeping management traffic on dedicated networks reachable only by administrators.

VMware vDefend is the security enforcement layer of this architecture and is where micro-segmentation lives. The distributed firewall instantiates a firewall at the virtual network interface of every workload, operating inside the hypervisor kernel on each ESX host, below the guest operating system. Because enforcement sits beneath the guest, a workload cannot bypass, disable, or tamper with its own network controls. NIST SP 800-207 identifies subversion of enforcement points as a threat to Zero Trust architectures; hypervisor-based enforcement addresses that threat by design. The distributed firewall supports a default-deny policy model in which only traffic explicitly permitted by policy is allowed and all other traffic is dropped, and it enforces Layer 2 through Layer 7 policy including application identity. The product is capable of default-deny; a deployment must be designed to use it.

Policy follows workload identity rather than network address. Distributed firewall policy groups determine membership dynamically from VM attributes, tags, and workload characteristics, so when a workload migrates between hosts its security policy moves with it. The Identity Firewall bases rules on Active Directory group membership, and Application ID recognizes applications by their actual network behavior rather than by port number, distinguishing different applications that share a port and preventing unauthorized services from operating on permitted ports. vDefend acts as a network-layer policy enforcement point, evaluating each flow against centrally defined policy and enforcing the decision at the virtual interface, the model the DoD describes as Resource Authorization.

vDefend supports a staged segmentation approach that produces value at each step. Infrastructure segmentation protects shared services such as DNS, directory services, and time synchronization behind dedicated rules. Environment segmentation establishes boundaries between zones such as development, staging, and production. Application segmentation defines the specific permitted communication paths between application tiers using application identity and Layer 7 context. This staged model provides a practical path from perimeter-based security toward least-privilege network access. VPC networking adds tenant-level isolation with configurable connectivity policies that control inter-VPC communication without changes to the underlying topology. In multi-site deployments, a Global Manager distributes vDefend policy to Local Managers across locations, providing consistent enforcement from a single management point.

VCF keeps a minimal set of network ports open, and management traffic is secured in transit using TLS, which reduces the platform's network attack surface. Encryption in transit is applied at multiple layers: vSAN data-in-transit encryption protects storage replication traffic between hosts, with hardware acceleration where supported, and Encrypted vMotion protects live-migration traffic. Certificate lifecycle management supports continuous compliance, with VCF Operations handling bulk certificate operations, auto-renewal, and non-disruptive replacement across the fleet.

VCF Operations for Networks and vDefend's Security Intelligence both support Data Flow Mapping, providing the network visibility needed to design segmentation boundaries. That visibility is discussed further in the Visibility and Analytics section.

Isolate Workloads: Application and Workload Protection

NIST Tenet 1. DoD Application and Workload pillar.

The DoD model requires that workloads be isolated so that compromise of one does not enable lateral movement to another, and it calls for integrity verification and application-level access controls. The capability set spans Application Inventory, Secure Software Development, Software Risk Management, Resource Authorization and Integration, and Continuous Monitoring and Ongoing Authorizations. VCF provides the isolation and resource-authorization mechanisms; the software development and supply-chain capabilities are organizational and toolchain responsibilities that an infrastructure platform does not provide.

VCF's hypervisor is the foundational isolation boundary. Virtual machines run in hardware-enforced isolation, each in its own address space, fully abstracted from the underlying hardware. Confidential computing support through Intel TDX and AMD SEV-SNP, available through VCF Advanced Cyber Compliance on supported hardware, extends this isolation to memory encryption with keys managed by the processor itself, reducing exposure of workload memory to the infrastructure layer and to infrastructure administrators when configured correctly. It strengthens workload isolation against the privileged-insider and infrastructure-administrator threat, but it does not replace guest operating system hardening, image integrity controls, identity governance, backup security, or operational change control.

Resource authorization is enforced consistently across the platform. VCF components evaluate and enforce access requests against defined permissions in real time within their respective management domains, and vDefend extends that model to the network by evaluating every flow against policy at the workload interface. On vSphere Supervisors, containers run within the same hypervisor-enforced isolation model, and namespace-level role-based access control restricts what a given identity can do within a Kubernetes namespace, so access to one namespace does not extend to another. Workloads are inventoried through vCenter and, at the network tier, through the Security Services Platform, which maintains an inventory of network-visible workloads organized by region, zone, environment, application, and application tier.

Within the management plane, VCF Management Services (VCFMS) runs platform components as containerized services, and administrators can separate the management plane from workloads by assigning dedicated vSphere Zones. The management plane is therefore segmented rather than monolithic, which limits how far a compromise of any single management service can spread.

Protect Data Throughout Its Lifecycle

NIST Tenet 2. DoD Data pillar.

The DoD Data pillar requires encryption at rest and in transit, data access monitoring, and key management, alongside data governance capabilities such as cataloging, labeling, and loss prevention. VCF provides the infrastructure-level data protection capabilities. Data classification, labeling, and content-aware data loss prevention are organizational and application-layer capabilities that VCF does not provide natively.

vSAN data-at-rest encryption protects stored data using keys from an external Key Management Server (KMS) or the vSphere Native Key Provider, so a device physically removed from a cluster yields no readable data. Because keys can be held in an external KMS, customers can retain control of their own encryption keys rather than delegating that control to the platform. VM encryption provides an additional layer at the virtual machine level, independent of the storage backend, and data-in-transit encryption for vSAN supports configurable rekey intervals with per-host key generation. Certain VCF components can be configured to use FIPS-validated cryptographic modules, subject to the validation status and configuration requirements for the specific component and release. This is not a blanket FIPS validation of VCF as a whole. Cryptographic keys are protected through the CryptoManager object hierarchy in the vSphere API, with controls spanning key storage, access, lifecycle, and availability.

For data access monitoring, VCF Log Management captures infrastructure and management-plane audit events across the stack, and the centralized, time-correlated audit trail records administrative and platform actions, scoped to VCF-managed objects: who did what, when, and from where. At the network layer, vDefend contributes to data monitoring and to limiting exfiltration: the distributed firewall restricts which workloads can communicate and over which protocols, narrowing the paths by which sensitive data could leave a segment, and integrates NSX tags with policy so that information-flow controls can reference data-classification metadata applied to workloads. vDefend does not include a content-aware data loss prevention engine, which remains a dedicated data-layer capability.

VCF Protection and Recovery, part of the VCF Advanced Cyber Compliance, extends data protection into the resilience domain. It replicates virtual machine workloads to secondary or isolated recovery environments, including geographically separated sites when designed that way, orchestrates disaster recovery, and supports ransomware recovery from an isolated recovery environment. Replication traffic is cryptographically protected, and the at-rest encryption of the underlying vSAN and VM data is preserved through the recovery workflow. Its contribution to Zero Trust is depth rather than breadth: it strengthens the Data pillar and the availability and denial-of-service considerations rather than opening capabilities the platform and vDefend do not already provide. Role-based access control restricts who can configure and run recovery operations, and the service forwards its own audit events to centralized logging.

See Everything: Visibility and Analytics

NIST Tenet 7. DoD Visibility and Analytics pillar.

The DoD model elevates visibility and analytics from a supporting function to a first-class Zero Trust requirement. Zero Trust is not only about preventing unauthorized access; it is equally about detecting anomalies, informing trust decisions with real-time data, and providing the telemetry that policy engines need to adapt. The capability set covers Log All Traffic, SIEM, Common Security and Risk Analytics, User and Entity Behavior Analytics, Threat Intelligence Integration, and Automated Dynamic Policies.

VCF centralizes platform, component, and audit logging through VCF Log Management. Logs use a standardized format with consistent timestamps, component identifiers, and structured fields, and audit records carry structured fields and audit identifiers that support correlation across components. VCF Log Management provides centralized collection and analysis, routes audit records to a dedicated audit partition with customizable retention, and forwards to third-party SIEM platforms for organizations that run separate security operations centers. Every major subsystem also supports syslog forwarding, so the logging output integrates with any platform that accepts standard syslog. The result is a centralized, time-correlated audit trail that produces event records containing the event type, timestamp, location, source, outcome, and user identity. This supports the DoD Log All Traffic capability at the infrastructure and network-security layers; it is not equivalent to full packet capture or enterprise-wide traffic logging.

VCF Operations contributes to common security and risk analytics through operational anomaly detection that uses dynamic and static thresholds to flag deviations from the normal operating behavior of monitored infrastructure and workloads. It is not a dedicated user and entity behavior analytics product, and organizations should expect to feed its output into one. VCF Operations for Networks collects metrics on distributed firewall rule counts, packet drops, and traffic patterns, and its micro-segmentation flow analysis identifies unprotected communication paths and gaps in firewall coverage.

vDefend adds the network-specific layers of visibility and analytics. Security Intelligence provides continuous traffic flow analysis and machine-learning-based recommendations for firewall rules, identifying traffic not covered by existing policy and flagging stale rules that no longer match real traffic. This supports the continuous policy refinement cycle that NIST SP 800-207 envisions. vDefend's Security Segmentation score quantifies how well actual traffic aligns with the intended security architecture, giving organizations a measurable indicator of their segmentation posture. Distributed IDS/IPS generates event logs with severity classification when intrusion indicators are detected, Advanced Threat Prevention extends detection to previously unseen threats using behavioral analysis and machine learning, and malicious-IP feed integration blocks traffic to and from known-malicious addresses using continuously updated threat intelligence. The Gateway Firewall's TLS inspection capability decrypts encrypted traffic to examine it for threats before re-encrypting and forwarding, so that encrypted channels do not become blind spots.

VCF does not provide SIEM, user and entity behavior analytics, or threat intelligence as products in their own right; it provides the telemetry and structured log data that feed those systems. Organizations pursuing a DoD-aligned Zero Trust architecture should plan to integrate the VCF, vDefend, and Protection and Recovery logging and detection output with a dedicated SIEM and analytics platform.

Automate the Response: Orchestration and Enforcement

DoD Automation and Orchestration pillar.

The DoD model requires automated compliance checking, configuration drift detection and remediation, and the ability to enforce security policy at scale without manual intervention. The capability set covers a Policy Decision Point and policy orchestration, Critical Process Automation, Machine Learning, Artificial Intelligence, Security Orchestration Automation and Response (SOAR), API Standardization, and the Security Operations Center and Incident Response function.

The clearest contribution here is network-layer policy enforcement. vDefend functions as a network-layer policy enforcement point, evaluating traffic against centrally authored policy and enforcing the result at or near the workload interface, with context profiles, Gateway Firewall Layer 7 access profiles, and Identity Firewall providing the attribute dimensions that policy can reference. Security Intelligence applies machine learning to recommend policy, feeding the network policy lifecycle, while the broader Policy Decision Point and policy-engine functions remain part of the enterprise Zero Trust architecture.

Compliance automation, delivered through the VCF Advanced Cyber Compliance (SaltStack-based remediation with Continuous Compliance Enablement), executes benchmark checks across appliances and applies remediation at fleet scale, with new benchmark content delivered as cryptographically signed packages outside the release cycle. Configuration drift detection compares running state against desired-state templates, and standardized configuration profiles are enforced across ESX hosts, with custom roles synchronized fleet-wide and automated drift notification. Certificate lifecycle management automates renewal and replacement, reducing the chance that an expired certificate creates a gap in mutual authentication, and password policy compliance runs on a regular schedule. VCF's API-driven architecture supports infrastructure-as-code practices: management operations are available through documented, authenticated, and encrypted APIs, so organizations can codify and version-control security policy alongside infrastructure configuration.

For the security operations and incident response function, VCF Operations supports notification rules with detailed incident field mappings, and vDefend contributes detection, classification, and containment: Security Intelligence categorizes events by impact (Critical, High, Medium, Low) and by MITRE ATT&CK tactic, and NDR correlates events into campaigns for triage. Full incident response process governance, and security orchestration, automation, and response across domains, depend on a dedicated SOAR platform; the VCF stack provides the detection signals and the enforcement actions that such a platform orchestrates.

Mapping to the NIST SP 800-207 Tenets

The ratings in this table and in the capability matrices later in the paper are scoped to infrastructure-layer capabilities supplied by core VCF, vDefend, and the VCF Advanced Cyber Compliance. They do not represent enterprise-wide Zero Trust maturity or compliance. Capabilities that require identity-provider policy, endpoint management, SIEM, UEBA, SOAR, data governance, application security tooling, or organizational process are marked as *Contributes* or *Supporting* even where the VCF stack provides enforcement points, telemetry, or automation hooks. No single product implements Zero Trust by itself.

The SCF crosswalk maps controls to all seven NIST 800-207 tenets, and the assessment shows the combined stack contributing to each. The table below gives the strongest contribution level observed for each product across the controls mapped to each tenet. *Meets* indicates the product performs the function described at the infrastructure layer; *Contributes* indicates it supplies a mechanism that an organization combines with its own process or with complementary products.

NIST SP 800-207 Tenet	VCF	vDefend	Protection and Recovery
1. All data sources and computing services are resources	Contributes	Contributes	Contributes
2. All communication is secured regardless of network location	Contributes	Contributes	Contributes
3. Access to individual resources is granted per-session	Contributes	Contributes	Contributes
4. Access is determined by dynamic policy	Contributes	Meets	Contributes
5. The enterprise monitors the integrity and posture of all assets	Meets	Meets	Contributes
6. Authentication and authorization are dynamic and enforced before access	Contributes	Contributes	Contributes
7. The enterprise collects state data and uses it to improve posture	Contributes	Contributes	Contributes

Mapping to the NIST SP 800-207 Deployment Approaches

NIST SP 800-207 describes three deployment approaches, and the DoD Reference Architecture expects a complete implementation to draw from all three. The VCF stack supports each.

Enhanced identity governance uses identity as the primary input to access decisions. VCF SSO federates with external identity providers through standard protocols, VCF-level roles provide centralized authorization, and the OAuth API client model supports non-human identities for automation.

Micro-segmentation places policy enforcement at the workload boundary. The vDefend distributed firewall, built on NSX, enforces rules at the virtual interface of every workload, dynamic security groups let policy follow workload identity rather than network address, and VPC connectivity policies provide inter-tenant isolation.

Network infrastructure and software-defined perimeters decouple workload connectivity from physical infrastructure. NSX overlay networking creates logical segments, VPC networking provides tenant-level isolation, and the management plane operates on logically separated network paths with controlled ingress points.

Mapping to the CISA Zero Trust Maturity Model

The CISA Zero Trust Maturity Model (version 2.0, April 2023) organizes Zero Trust into five pillars (Identity, Devices, Networks, Applications and Workloads, and Data) and three cross-cutting capabilities (Visibility and Analytics, Automation and Orchestration, and Governance), each assessed across four stages: Traditional, Initial, Advanced, and Optimal. These pillars correspond closely to the DoD pillars and NIST tenets assessed in the previous sections, so the same capability evidence maps onto the CISA model. The Advanced and Optimal stages depend on automation and organizational process beyond any platform; the table describes the maximum stage the stack's technical capabilities can support when integrated, and the functions it addresses within each pillar.

CISA ZTMM Pillar or Capability	Functions the stack addresses	Maximum stage supported when integrated
Identity	Authentication and Identity Stores through VCF SSO federation; Access Management through platform-wide RBAC and least privilege; multifactor and risk-based authentication through the enterprise identity provider	Advanced
Devices	Device Threat Protection through Secure Boot and TPM attestation; Policy Enforcement and Compliance Monitoring through VCF Operations Security Posture Management and Continuous Compliance Enablement (Advanced Service); Resource Access through certificate-based device authentication	Advanced
Networks	Network Segmentation through vDefend micro-segmentation; Network Traffic Management through Application ID and Layer 7 policy; Traffic Encryption through vSAN data-in-transit and Encrypted vMotion; Network Resilience through NSX multi-site and VCF Protection and Recovery	Advanced
Applications and Workloads	Application Access through Identity Firewall and Application ID; Application Threat Protections through IDS/IPS, Advanced Threat Prevention, and NDR. Secure application development and security testing are organizational and toolchain functions outside the stack	Initial toward Advanced
Data	Data Encryption through vSAN and VM encryption with customer-controllable keys; Data Access through RBAC and microsegmentation; Data Availability through Protection and Recovery. Data Categorization and data inventory remain organizational	Advanced
Visibility and Analytics	VCF Log Management, VCF Operations, and vDefend Security Intelligence, IDS/IPS, and NDR	Advanced
Automation and Orchestration	Compliance automation (Advanced Service), network policy orchestration, and the API-driven, infrastructure-as-code architecture	Advanced
Governance	An organizational function; the stack supplies the enforcement points and audit data that a governance program directs, rather than providing governance itself	Supporting only (organizational)

vDefend's Security Intelligence rule recommendations continuously refine segmentation policy from observed traffic, which supports the Optimal stage for segmentation-policy management specifically, not the entire Networks pillar. The Governance capability, along with Data Categorization, secure application development, and the fully automated highest stage of each pillar, depends on organizational process and tooling beyond the platform.

Mitigating ZTA Threats from SP 800-207

SP 800-207 identifies several threats to Zero Trust implementations. The VCF stack helps mitigate each.

Subversion of the policy decision process. The centralized, time-correlated audit trail, integrity monitoring on management appliances, and controls over log sources make it difficult to tamper with policy infrastructure without detection.

Denial of service or network disruption. High-availability deployment modes across the platform allow continued operation during component outages, and VCF Protection and Recovery (part of the VCF Advanced Cyber Compliance) adds replication, disaster-recovery orchestration, and ransomware recovery for restoring service and data after a disruptive event.

Stolen credentials and insider threat. Configurable token lifetimes, least-privilege scoping, narrowly scoped role-based permissions for service accounts, multifactor authentication enforced through federated identity providers, and confidential computing for hardware-level isolation all reduce the impact of compromised credentials.

Visibility on the network. VCF Operations for Networks collects traffic metadata and flow analysis without requiring payload decryption, and vDefend's micro-segmentation flow analysis surfaces communication patterns for policy refinement.

Storage of system and network information. Role-based access to monitoring data, together with a separate audit partition that has independent retention, limits exposure of security telemetry.

Reliance on proprietary data formats. The identity layer uses industry-standard federation and authentication protocols (OIDC, SAML), and syslog forwarding and documented APIs support integration with third-party platforms.

Use of non-person entities in ZTA administration. Narrowly scoped service-account permissions and configurable token lifetimes address the risk from automated agents that would otherwise rely on weaker, longer-lived authentication.

Capability Coverage Matrices

The matrices below summarize, per offering, the DoD Zero Trust capabilities each one addresses and the specific feature that does the work. They are presented separately so readers can see which capability sits in core VCF, in vDefend, or in VCF Advanced Cyber Compliance. Capability identifiers are the DoD Zero Trust Capability Execution Roadmap numbers (for example, 5.4 Micro Segmentation and 3.4 Resource Authorization), which match the SCF crosswalk used in this paper. The Roadmap numbers capabilities by pillar as 1 User, 2 Device, 3 Application and Workload, 4 Data, 5 Network and Environment, 6 Automation and Orchestration, and 7 Visibility and Analytics; this capability-numbering order differs from the pillar reading order used in the section headings above, so the identifiers may not match a reader's expected pillar sequence. The Contribution column distinguishes a *Direct* capability, where the product performs the function described, from a *Supporting* capability, where the product supplies a mechanism that an organization combines with its own process or with complementary products. These describe product function; they are not a compliance attestation against the DoD standard.

VMware Cloud Foundation

DoD ZT Capability	VCF Feature	Contribution
1.1 User Inventory	VCF SSO identity store and component account management	Supporting
1.2 Conditional User Access	Role-conditional access through RBAC across vCenter, NSX, VCF Operations, VCF Automation, and VMware Kubernetes Service (VKS); contextual, device, and session conditions are enforced through the identity provider	Supporting
1.3 Multi-Factor Authentication	Enforced through the federated identity provider	Supporting
1.4 Privileged Access Management	RBAC privilege scoping; participates in just-in-time and time-limited workflows via enterprise PAM integration	Supporting
1.5 Identity Federation and Credentialing	VCF SSO federation via supported SAML, OIDC, and directory-based integrations	Direct
1.6 Behavioral, Contextual ID	VCF Operations operational anomaly detection (not a dedicated UEBA)	Supporting
1.7 Least Privileged Access	Granular RBAC scoped by function and inventory location	Direct
1.8 Continuous Authentication	Federation, token lifetimes, and session controls provide integration points; continuous authentication depends on IdP, PAM, conditional access, and session-risk tooling	Supporting
1.9 Integrated ICAM Platform	VMCA, certificate lifecycle management, and federation support integration with enterprise ICAM	Supporting
2.1 Device Inventory	vCenter authoritative inventory; VCF Operations configuration-item record; VMCA device authentication	Direct
2.2 Device Detection and Compliance	VCF Operations inventory and discovery; NSX Edge gateways as managed network entry points	Supporting
2.3 Device Authorization with Real-Time Inspection	Secure Boot, TPM Measured Boot attestation, and VMCA PKI establish host trust; tying attestation to live authorization decisions requires additional policy integration	Supporting
2.5 Asset, Vulnerability and Patch Management	VCF lifecycle management (including vSphere Lifecycle Manager functions) and VCF Operations unified patching; configuration drift detection	Direct
2.7 Endpoint and Extended Detection and Response	Host integrity controls, log analysis, and forwarding to EDR/XDR/SIEM; partner integration	Supporting
3.1 Application Inventory	vCenter and VCF Operations inventory of workloads	Supporting

3.3 Software Risk Management	Software artifact integrity and controlled distribution (content library policies, signing); does not provide application software risk management	Supporting
3.4 Resource Authorization and Integration	Real-time authorization enforcement; vSphere VM isolation; Supervisor namespace RBAC	Direct
3.5 Continuous Monitoring and Ongoing Authorizations	VCF Operations and VCF Log Management centralized monitoring and log aggregation	Direct
4.1 Data Catalog Risk Alignment	VCF Operations for Networks flow analysis; infrastructure asset mapping	Supporting
4.3 Data Labeling and Tagging	vSphere Tag Service and storage/compute policy metadata (not a classification product)	Supporting
4.5 Data Encryption and Rights Management	vSAN data-at-rest encryption, VM encryption, FIPS-validated modules, external KMS / Native Key Provider	Supporting
4.7 Data Access Control	vSAN software-defined storage; layered RBAC, encryption privilege, and secrets management	Direct
5.1 Data Flow Mapping	VCF Operations for Networks end-to-end network map and flow analysis	Supporting
5.2 Software Defined Networking	NSX logical networking: overlays, routing, and transport zones; network asset discovery	Direct
5.3 Macro Segmentation	Network partitioning through VLANs, vSphere Distributed Switches, and NSX overlay segments and routing domains	Direct
5.4 Micro Segmentation	NSX logical-networking foundation and VCF Operations for Networks planning and flow analysis (segmentation enforcement performed by vDefend)	Supporting
6.1 Policy Decision Point and Orchestration	Real-time authorization enforcement within each management domain	Supporting
6.6 API Standardization	Authenticated, authorized, and encrypted APIs across components, including VKS	Supporting
6.7 Security Operations Center and Incident Response	VCF Operations notification rules and incident field mapping	Supporting
7.1 Log All Traffic	Centralized platform audit and event logging with a time-correlated audit trail and syslog forwarding; network traffic logging depends on NSX and vDefend policy	Supporting
7.2 Security Information and Event Management	Log management and analytics; near-real-time analysis, correlation, and forwarding to external SIEM (not a SIEM itself)	Supporting
7.3 Common Security and Risk Analytics	VCF Operations cross-stack monitoring and analytics	Supporting
7.4 User and Entity Behavior Analytics	Infrastructure anomaly detection that can feed UEBA and SIEM platforms; not native UEBA	Supporting

Capabilities from the **VCF Advanced Cyber Compliance** Advanced Service, which is licensed separately, appear in their own matrix below rather than here: Confidential Computing (which deepens the workload isolation in 3.4 Resource Authorization), VCF Operations Security Posture Management (the posture assessment and compliance benchmarks described in the Device pillar), and Continuous Compliance Enablement (automated compliance verification and remediation). The host-trust and patching capabilities in rows 2.3 and 2.5 (Secure Boot, TPM attestation, and lifecycle patching) are part of core VCF.

Capabilities not addressed, because they are organizational or toolchain functions or apply to user endpoints: 2.4 Remote Access (user access layer), 2.6 UEM/MDM, 3.2 Secure Software Development, 4.2 DoD Enterprise Data Governance, 4.4 Data Monitoring and Sensing (content layer), 4.6 Data Loss Prevention, 6.2 Critical Process Automation, 6.3 Machine Learning, 6.4 Artificial Intelligence, 7.5 Threat Intelligence Integration, and 7.6 Automated Dynamic Policies.

VMware vDefend

DoD ZT Capability	vDefend Feature	Contribution
1.2 Conditional User Access	Identity Firewall: AD user/group-aware network policy	Supporting
1.4 Privileged Access Management	Role-based access control over its own management plane (Security Services Platform) with differentiated built-in roles; not a privileged access management product	Supporting
2.1 Device Inventory	Security Services Platform workload inventory; NDR sensor mTLS onboarding	Supporting
2.3 Device Authorization with Real-Time Inspection	Security Intelligence, IDS/IPS, and NDR continuous threat visibility	Supporting
2.7 Endpoint and Extended Detection and Response	Network Detection and Response with MITRE ATT&CK mapping (network-layer detection and response, not endpoint EDR)	Supporting
3.4 Resource Authorization and Integration	Distributed firewall as network-layer policy enforcement point with local policy evaluation; dynamic, attribute-based groups	Direct
4.4 Data Monitoring and Sensing	Restricts and observes workload communication paths through tag-based firewall policy; does not inspect or classify data content	Supporting
4.6 Data Loss Prevention	Distributed firewall restriction of exfiltration paths (not content-aware DLP)	Supporting
5.1 Data Flow Mapping	Security Intelligence live traffic flow visualization and security posture mapping	Direct
5.2 Software Defined Networking	Security enforcement within the NSX-provided SDN; distributed firewall at the vNIC (NSX provides the SDN itself)	Supporting
5.3 Macro Segmentation	Perimeter and zone segmentation through the distributed and gateway firewalls	Direct
5.4 Micro Segmentation	Distributed firewall at every workload vNIC; configurable Layer 2 to Layer 7 default-deny policy	Direct
6.1 Policy Decision Point and Orchestration	Policy enforcement at or near the workload interface using context profiles, Gateway Firewall L7 access profiles, and Identity Firewall, plus ML-assisted policy recommendations; central decision functions remain part of the enterprise architecture	Supporting
6.7 Security Operations Center and Incident Response	Security Intelligence impact and MITRE classification; NDR campaign timelines; containment actions through firewall policy and integrations	Supporting
7.1 Log All Traffic	Policy-scoped firewall and security-event logging (configuration-dependent; not universal packet capture)	Supporting
7.2 Security Information and Event Management	Structured event data and dashboards; forwarding to external SIEM (not a SIEM itself)	Supporting
7.3 Common Security and Risk Analytics	Security Intelligence continuous flow analysis and trend reporting	Supporting

7.5 Threat Intelligence Integration	Advanced Threat Prevention, malicious-IP feeds, and continuously updated IDS/IPS signatures	Supporting
-------------------------------------	---	------------

vDefend's Security Segmentation score, a measurable indicator of how closely real traffic matches intended segmentation, reinforces its Micro Segmentation and Visibility contributions.

VCF Advanced Cyber Compliance

VCF Advanced Cyber Compliance provides entitlement to, or enables, capabilities such as cyber and disaster recovery (VCF Protection and Recovery), confidential computing, compliance enforcement, and policy-based VPC connectivity, subject to version, deployment model, and entitlement. The capabilities below come from these components, each of which has its own deployment and control surface. VCF Protection and Recovery adds resilience depth rather than new Zero Trust capability: the capabilities it covers are also covered by core VCF or vDefend, and it contributes recovery-specific mechanisms on top. Its distinctive value is data resilience: replication to secondary or isolated recovery environments, disaster-recovery orchestration, and ransomware recovery.

DoD ZT Capability	Component and feature	Contribution
2.5 Asset, Vulnerability and Patch Management	VCF Protection and Recovery: configurable security baseline for the replication and recovery appliances	Supporting
3.5 Continuous Monitoring and Ongoing Authorizations	VCF Protection and Recovery: disaster-recovery monitoring integrated with VCF Operations	Supporting
4.5 Data Encryption and Rights Management	VCF Protection and Recovery: encryption of replication traffic, cryptographic key management across recovery operations, and preservation of the underlying vSAN and VM at-rest encryption	Supporting
4.7 Data Access Control	VCF Protection and Recovery: role-based access control restricting who can configure and run recovery operations	Supporting
6.5 Security Orchestration, Automation and Response	Continuous Compliance Enablement: automated compliance verification and remediation through VCF Operations (infrastructure scope)	Supporting
6.6 API Standardization	VCF Protection and Recovery: unified REST API gateway with certificate-based trust	Supporting

Conclusion

VMware Cloud Foundation, with the VMware vDefend and VCF Advanced Cyber Compliance advanced services, provides the infrastructure-level capabilities organizations need to build a Zero Trust architecture aligned with both NIST SP 800-207 and the DoD Zero Trust Reference Architecture. Identity federation and role management address the User pillar. Host attestation, inventory, compliance, and patch automation address the Device pillar. Software-defined networking and distributed firewall enforcement address the Network and Environment pillar, the area of strongest coverage. Hypervisor-enforced isolation and confidential computing address the Application and Workload pillar. Encryption at rest and in transit with customer-controllable keys, complemented by replication and recovery, addresses the Data pillar. A centralized, standardized audit trail with network detection and response addresses the Visibility and Analytics pillar. Compliance automation, drift management, and network policy orchestration address the Automation and Orchestration pillar.

No single product implements Zero Trust by itself. Zero Trust is an architectural strategy that spans technology, process, and organizational commitment. Core VCF provides the platform on which that strategy is built, vDefend provides the network security enforcement and detection layer, and the VCF Advanced Cyber Compliance adds confidential computing, continuous compliance, and the resilience to recover from a disruptive event. All of them work in concert with enterprise identity

infrastructure, SIEM and analytics platforms, data-governance tooling, and security operations processes to complete the architecture.

Resources

NIST Special Publication 800-207, *Zero Trust Architecture*:

<https://csrc.nist.gov/pubs/sp/800/207/final>

DoD Zero Trust Reference Architecture, Version 2.0:

[https://dodcio.defense.gov/Portals/0/Documents/Library/\(U\)ZT_RA_v2.0\(U\)_Sep22.pdf](https://dodcio.defense.gov/Portals/0/Documents/Library/(U)ZT_RA_v2.0(U)_Sep22.pdf)

DoD Zero Trust Strategy:

<https://dodcio.defense.gov/Portals/0/Documents/Library/DoD-ZTStrategy.pdf>

DoD Zero Trust Capability Execution Roadmap, Version 1.1:

<https://dodcio.defense.gov/Portals/0/Documents/Library/ZT-ExecutionRoadmap-v1.1.pdf>

CISA Zero Trust Maturity Model, Version 2.0:

<https://www.cisa.gov/zero-trust-maturity-model>

VMware Security & Compliance Guidance:

<https://brcm.tech/vcf-security>

<https://github.com/vmware/vcf-security-and-compliance-guidelines/>

